



Enterprise IT Compliance & Governance Framework

Complete Policy Portfolio featuring Automated Gated Verification

Document ID:	ECF-2026-v1.1
Author:	IT Compliance Portfolio Project
Standards Framework:	ISO/IEC 27001:2022 SOC 2 Type II (Trust Services Criteria)
Classification:	Public Portfolio Demonstration
Last Reviewed:	July 2026

POL-CM-01: Secure Software Development & Change Management Policy

Compliance Matrix Mapping:

ISO 27001:2022: Control A.8.32 (Change Management) & A.8.25 (Secure Development)

SOC 2 Type II: Common Criteria 8.1 (Change Management & Lifecycle Controls)

1. Purpose

This policy defines the mandatory controls for proposing, developing, reviewing, testing, and deploying changes to production systems and codebases to minimize operational and security risks.

2. Scope

This policy applies to all source code repositories, configurations, infrastructure-as-code (IaC), and continuous integration/continuous deployment (CI/CD) pipelines managed under the Enterprise GitHub Organization.

3. GitHub Policy-as-Code Controls (Mandatory)

3.1 Repository Rulesets & Branch Protection

All production branch deployments (e.g., `main`, `master`, `production`) must enforce GitHub Repository Rulesets with the following minimum configurations:

- **Require a pull request before merging:** Direct pushes to default branches are strictly prohibited.
- **Required approvals:** A minimum of **two (2) independent peer reviews** (Write access or higher) must approve any PR before merge.
- **Code Owner Reviews:** If changes impact sensitive directories (e.g., `/infrastructure`, `/auth`), approval must be secured from designated individuals defined in the `CODEOWNERS` file.
- **Require status checks to pass:** Prior to merging, all automated CI pipelines (linters, unit tests, vulnerability scanners) must complete successfully.
- **Dismiss stale pull request approvals:** If a branch is updated after an approval, existing approvals are automatically revoked, requiring a re-review.
- **Restrict deletions:** Branch deletion of default or protected branches is restricted to Organization Administrators.

3.2 Commit Signing

- All commits must be cryptographically signed (GPG, SSH, or S/MIME keys) to guarantee authenticity and non-repudiation.
- Unsigned commits will be rejected automatically by GitHub push protection rules.

3.3 Security Gates

- **Static Application Security Testing (SAST):** GitHub Advanced Security (CodeQL) must run on every pull request. No PR can be merged with unresolved "High" or "Critical" vulnerability alerts.
- **Secret Scanning:** Active push protection must be enabled organization-wide to block commits containing plaintext API keys, passwords, or certificates.

POL-AC-01: Identity, Authentication, and Access Control Policy

Compliance Matrix Mapping:

ISO 27001:2022: Control A.5.15 to A.5.18 (Access Control & Identity Management)

SOC 2 Type II: Common Criteria 6.1, 6.2, 6.3 (Access & Logical Identity Controls)

1. Purpose

To establish cryptographic identity verification, mandate the Principle of Least Privilege, and ensure strict credential management to protect organizational resources on GitHub.

2. Scope

Applies to all internal employees, contractors, third-party collaborators, and automated service accounts accessing the GitHub organization.

3. Mandatory Access Controls

3.1 Authentication & Multi-Factor Authentication (MFA)

- **Identity Provider (IdP) Integration:** All users must authenticate via Enterprise Single Sign-On (SSO) integrated with the company's centralized Directory (e.g., Okta, Entra ID).
- **Enforced MFA:** Multi-Factor Authentication (MFA) is strictly required for all GitHub accounts within the organization. Accounts failing to enroll in MFA within 24 hours of invitation will be automatically deprovisioned.
- **Session Lifetimes:** Idle sessions on GitHub Enterprise UI must be restricted to a maximum of 8 hours before requiring re-authentication.

3.2 Access Provisioning & Least Privilege

- **Default Permissions:** The default base permission for all organization members is set to **Read** only.
- **Role-Based Access Control (RBAC):** Repository access must be granted using GitHub Teams. Direct individual user assignments to repositories are strictly prohibited.
- **Collaborator Policy:** External, third-party collaborators may only be added to private repositories with formal approval from the Information Security Team, subject to a bi-annual access review.

3.3 Token & Credential Lifetimes

- **Personal Access Tokens (PATs):** Only fine-grained Personal Access Tokens are permitted. Classic PATs are blocked at the organization policy level.
- **Token Expiration:** No PAT may exceed an expiration window of **30 days**.
- **IP Allow List:** Access to the Enterprise Organization resources via SSH, HTTPS, or API is restricted to authorized company VPN IP ranges.

POL-IR-01: Information Security Incident Management Policy

Compliance Matrix Mapping:

ISO 27001:2022: Control A.5.24 to A.5.28 (Information Security Incident Management)

SOC 2 Type II: Common Criteria 7.3, 7.4 (Incident Identification, Mitigation, & Response)

1. Purpose

This policy establishes a coordinated approach to identifying, classifying, managing, and resolving information security incidents. The objective is to minimize operational downtime, protect organizational assets, and fulfill legal, regulatory, and contractual notification obligations.

2. Scope

This policy applies to all production environments, corporate infrastructure, source code repositories, and physical facilities. It encompasses all employees, contractors, and third-party vendors operating on behalf of the organization.

3. Incident Governance & Ownership

- **Policy Owner:** Head of Information Security / CISO.
- **Primary Responders:** Dedicated Security Team (SecOps).
- **System of Record:** All incident tracking, communication, and post-mortem notes must be documented within the centralized **Jira Service Management (JSM)** system under the designated Security project ([SEC-IR](#)).

4. Incident Lifecycle Procedures

Phase 1: Identification & Logging

- **Internal Reporting:** Any employee who suspects a security anomaly or data breach must raise an emergency ticket via the **Jira Service Desk Portal** immediately.
- **Automated Alerting:** Continuous monitoring systems (SIEM, log aggregators, and runtime cloud security tools) are configured to automatically generate high-priority tickets within Jira via webhook integration upon detecting anomalous behavior.

- **Centralized Registry:** To guarantee an immutable audit trail for SOC 2 and ISO 27001 auditors, Jira ticket deletions are strictly disabled across the organization.

Phase 2: Classification & Severity Matrix

Upon ticket creation, the **Dedicated Security Team** must instantly triage the event based on the following framework:

Severity Level	Definition	Response SLA	Escalation Path
P1 - Critical	Active data breach involving PII/sensitive data, or total production outage.	Within 30 Mins	Dedicated Security Team, Legal, CISO, Executive Board
P2 - High	Localized system compromise or partial degradation of critical production services.	Within 2 Hours	Dedicated Security Team, IT Infrastructure Lead
P3 - Medium	Isolated malware detection on an endpoint or minor policy violation with no data loss.	Within 12 Hours	On-Duty Security Analyst
P4 - Low	Phishing attempt reported by user; standard vulnerability scan findings.	Within 24 Hours	Helpdesk / IT Support Tier 1

Phase 3: Containment, Eradication, & Recovery

- **Containment:** The Dedicated Security Team will execute immediate tactical actions to limit the blast radius (e.g., isolating networks, rotating compromised keys, revoking credential access).
- **Eradication:** The Security Team, in coordination with Engineering, will neutralize the root cause (e.g., purging malicious binaries, rebuilding affected microservices from known secure images).
- **Recovery:** Systems must be safely restored to normal operations using verified, clean backups, followed by a minimum of 48 hours of enhanced logging and monitoring.

Phase 4: Regulatory & Contractual Notifications

- **Strict Data Privacy Mandate:** In compliance with strict regional and global data privacy regulations, if a P1 incident involves unauthorized access, alteration, or exposure of Personal Identifiable Information (PII), the Compliance Officer and Legal Team must notify the relevant Privacy Authorities and affected data subjects **within 72 hours** of breach confirmation.
- **Auditor Tracking:** All regulatory notifications, correspondence, and evidence logs must be attached directly to the corresponding Jira incident ticket to satisfy SOC 2 CC7.3/CC7.4 criteria.

Phase 5: Post-Incident Review & Lessons Learned

- For all **P1** and **P2** incidents, the Dedicated Security Team must lead a formal Post-Incident Review (PIR) within five (5) business days of resolution.

- The review must document the root cause, timeline of events, containment efficacy, and permanent preventative fixes.
- The finalized PIR report must be attached to the Jira issue, and the ticket status marked as **Resolved-Closed** only after engineering management sign-off.

SEC-WF-01: GitHub Actions CI/CD Security Workflow



Compliance Matrix Mapping:

CIS Controls: Control 16 (Application Software Security)

Continuous Auditing: Automated Policy Linting & Verification

1. Policy Overview

This automated executable script serves as a technical continuous auditing check. It monitors documentation updates to verify styling consistency, layout, and structure alignment before merging documentation changes into the production system.

2. Executable Code Block (YAML Syntax)

File Path: `.github/workflows/compliance-gate.yml`

```
name: Compliance Verification Gate

on:
  pull_request:
    branches: [ main ]
    paths:
      - '**.md' # Trigger on policy updates

jobs:
  compliance-audit:
    name: Lint & Audit Policy Documents
    runs-on: ubuntu-latest

    steps:
      - name: Checkout Repository Code
        uses: actions/checkout@v4

      - name: Lint Markdown Files for Accessibility and Standards
        uses: DavidAnson/github-markdown-lint@v1
        with:
          config: '{"default": true, "MD013": false}'

      - name: Policy Verification Status
        run: |
          echo "Compliance Verification Check Passed Successfully."
          echo "All modifications adhere to documentation governance templates."
```